

PISA: Portable IoT Security Assessment Platform

Architecture Description | System Design Document

System Overview

PISA is a fully portable, edge-native IoT security assessment platform built on a Raspberry Pi 4. The architecture is organized into five vertical layers — Physical Hardware, System Software, Network Discovery, Security Assessment, and Application — each building directly on the one below it. All core functionality executes locally on the device with no mandatory cloud dependency, making the system viable for air-gapped field environments. An optional cloud integration channel runs alongside all layers to enable report synchronization, remote collaboration, and threat intelligence caching. Data flows upward from raw radio frames at the hardware layer through progressive stages of analysis, culminating in prioritized vulnerability findings and actionable reports at the application layer.

Layer 0 — Physical Hardware (Edge Node)

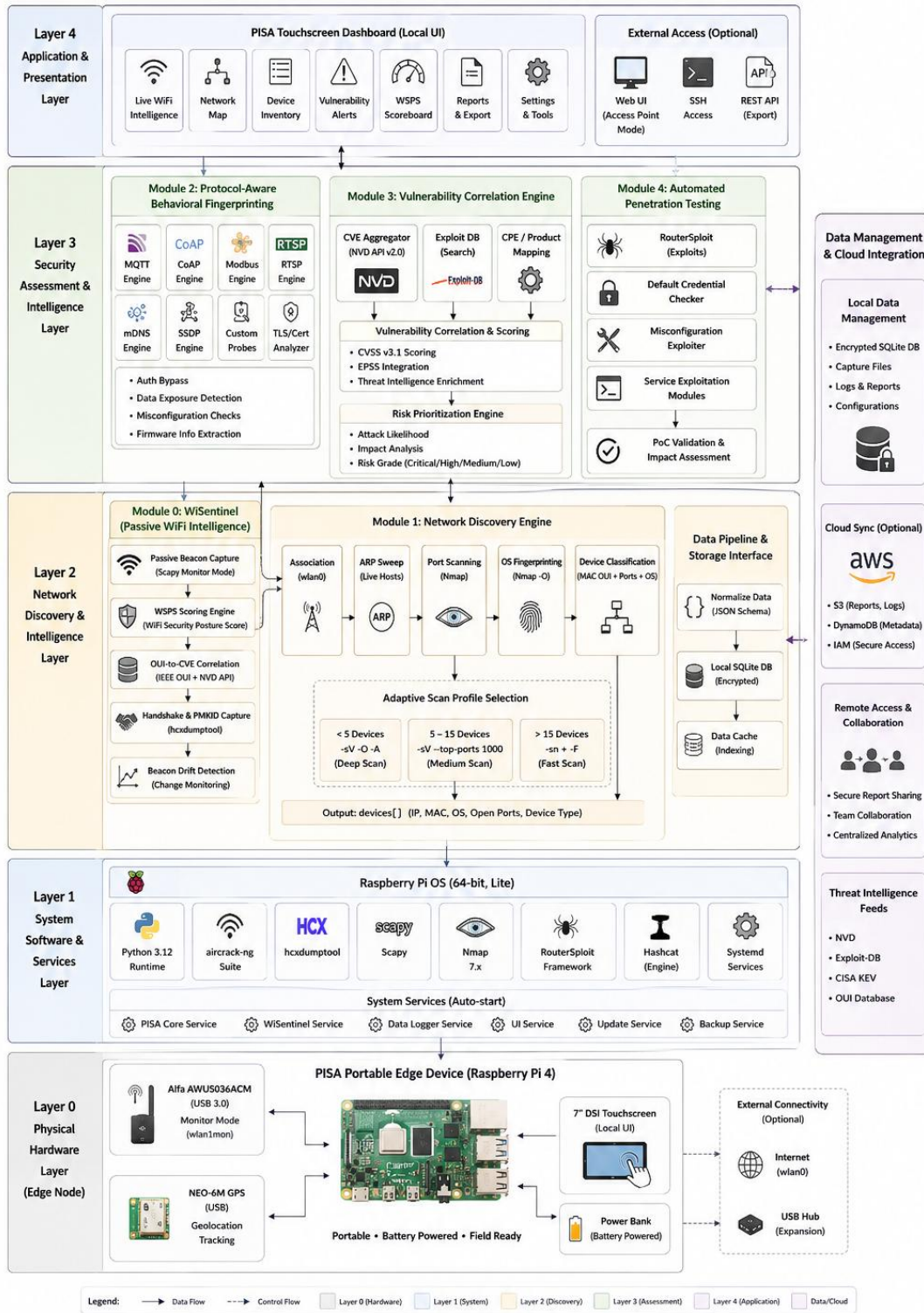
The platform is anchored by a **Raspberry Pi 4 (4GB RAM)** powered by a portable power bank, making the entire system battery-operated and field-deployable without any infrastructure dependency. An **Alfa AWUS036ACM USB 3.0 Wi-Fi adapter** is dedicated exclusively to passive monitoring on the wlan1mon interface — it never transmits, never associates, and never disrupts the target environment. The onboard **wlan0** interface handles all active network operations and internet connectivity on a completely separate channel, eliminating interference between capture and communication. A **NEO-6M GPS module** attaches via USB and tags every scan session with geolocation coordinates, enabling field deployment mapping across multiple site assessments. The **7-inch DSI touchscreen** connects directly to the board display interface, providing a zero-latency local UI with no additional hardware required.

Layer 1 — System Software & Services

The operating system is **Raspberry Pi OS 64-bit Lite** — headless at the OS level, keeping maximum CPU and memory available for security processing. **Python 3.12** serves as the primary runtime for all modules. The supporting toolchain includes: **aircrack-ng** for wireless interface management and handshake processing, **hcxdumpool** for PMKID extraction, **Scapy** for raw packet construction and parsing, **Nmap 7.x** for network scanning and OS fingerprinting, **RouterSploit** for exploit execution, and **Hashcat** for offline password cracking. Six systemd services — PISA Core, WiSentinel, Data Logger, UI, Update, and Backup — launch automatically on boot, requiring zero manual intervention in the field. Threat intelligence feeds from **NVD**, **Exploit-DB**, **CISA KEV**, and the **IEEE OUI database** are

consumed at this layer and cached locally so the system remains fully functional without an active internet connection.

PISA: Portable IoT Security Assessment Platform – Architecture



Layer 2 – Network Discovery & Intelligence

Module 0 – WiSentinel (Passive WiFi Intelligence)

WiSentinel operates continuously in the background throughout the entire assessment session. It passively captures 802.11 beacon frames via Scapy and computes a **WiFi Security Posture Score (WSPS)** for every visible access point, grading each network **A through F** based on encryption standard, Management Frame Protection status, cipher suite strength, SSID characteristics, and beacon interval behavior. Concurrently, it correlates each access point MAC OUI against the NVD API to surface CVEs associated with the device vendor – performing this **OUI-to-CVE mapping entirely on edge hardware** with no server required. It also monitors for **beacon drift** – detecting changes in encryption type, SSID, or capability flags across consecutive scans that may indicate a rogue AP or Evil Twin attack. Handshake and PMKID captures are handled via hcxdump tool and forwarded to Hashcat for offline password cracking.

Module 1 – Network Discovery Engine

Module 1 activates once the operator selects a target network. It associates with the target via wlan0, performs an **ARP broadcast sweep** to enumerate all live hosts, and feeds each discovered IP into Nmap for port scanning and OS fingerprinting. Device type is then determined by correlating three signals: MAC OUI vendor, open port signatures, and OS family – for example, an Espressif OUI with port 1883 open resolves to an ESP32 MQTT node, while a Hikvision OUI with port 554 resolves to an IP camera. Scan depth is automatically adjusted via an **Adaptive Scan Profile**: deep full-service scanning for fewer than five devices, top-1000-port scanning for five to fifteen devices, and a fast sweep for larger networks – a deliberate design choice that respects the Pi 4 processing constraints without sacrificing coverage on typical IoT deployments. All output is normalized to a unified JSON schema, written to an **encrypted local SQLite database**, and optionally synchronized to AWS S3 and DynamoDB.

Layer 3 – Security Assessment & Intelligence

Layer 3 processes the discovered device inventory through three tightly coupled modules that perform deep protocol analysis, vulnerability correlation, and controlled exploit validation.

Module 2 – Protocol-Aware Behavioral Fingerprinting

Module 2 deploys **eight concurrent probe engines** against each device: MQTT (paho-mqtt), CoAP (aiocoap), Modbus (pymodbus), RTSP (custom socket), mDNS, SSDP, vendor-specific custom probes, and a TLS/Certificate analyzer. Each engine interrogates the device for authentication bypass vulnerabilities, plaintext data exposure, service misconfigurations, firmware version disclosure, and certificate weaknesses. The confidence scores produced by all active engines for a given device are fused using the **cross-protocol formula $C = 1 -$**

product(1 - ci), which combines independent evidence streams into a single composite risk confidence value — without any reliance on machine learning.

Module 3 — Vulnerability Correlation Engine

Module 3 aggregates CVE data from three sources simultaneously: **NVD API v2.0** for base CVE records, **Exploit-DB** for confirmed public exploit availability, and **CISA KEV** for active real-world exploitation status. Device attributes are mapped to standardized CPE identifiers to ensure precise NVD query targeting. Each CVE is then scored using the **Tri-Metric ExploitScore** formula — a weighted combination of CVSS v3.1 base score (40%), EPSS exploitation probability (35%), and KEV membership (25%) — producing a final risk grade of **Critical, High, Medium, or Low** for every finding.

Module 4 — Automated Penetration Testing

Module 4 acts on the prioritized CVE list through four mechanisms: **RouterSploit exploit matching** for CVE-linked vulnerabilities, **automated default credential testing** across HTTP, Telnet, SSH, and FTP services, **misconfiguration exploitation** for exposed management interfaces and unauthenticated services, and **service-specific attack modules** targeting protocol weaknesses identified in Module 2. Every action is gated behind an **explicit operator authorization prompt** with a countdown confirmation window, ensuring no exploit executes without deliberate human approval. All activity is timestamped, attributed to the operator, and stored as tamper-evident audit evidence in both local SQLite and the AWS evidence bucket.

Layer 4 — Application & Presentation

The **Flask-based touchscreen dashboard** presents the full assessment workflow through seven interface panels: **Live WiFi Intelligence** (real-time WiSentinel feed with WSPS grades), **Network Map** (interactive device topology), **Device Inventory** (complete asset table with risk scores), **Vulnerability Alerts** (CVE findings ranked by ExploitScore), **WSPS Scoreboard** (all nearby networks graded), **Reports and Export** (one-click PDF generation and JSON data export), and **Settings and Tools** (scan profiles, API configuration, system status). The interface is optimized for 800x480 touch operation, requiring no keyboard or mouse. For team-based field operations, the platform optionally activates an **Access Point mode** serving the same dashboard to connected devices over a local Wi-Fi hotspot. **SSH terminal access** and a **REST API** are also available for advanced operators and programmatic integration with external security toolchains.

Cloud & Data Integration

The optional cloud integration layer enhances but never blocks core functionality. **AWS S3** stores generated reports and raw logs. **DynamoDB** holds structured session metadata queryable from anywhere. **Lambda functions** handle PDF report generation and run nightly

CVE cache refreshes to keep threat intelligence current. **SNS** delivers critical findings via email notification to the operator. All primary data is stored locally in an **AES-256 encrypted SQLite database**, ensuring that assessment findings remain protected on the device regardless of connectivity. The architecture is deliberately **offline-first**: the cloud is an enhancement, not a dependency.

Summary

PISA realizes a complete, self-contained IoT security assessment pipeline on a single portable device — from passive radio-frequency intelligence at Layer 0 to prioritized, evidence-backed vulnerability reports at Layer 4. Each layer adds a distinct and necessary capability, no layer is redundant, and every data flow between them carries a specific security finding that advances the assessment toward actionable conclusions. The result is a platform that any security practitioner can carry into the field, operate from a touchscreen, and walk away with a structured, scored, and documented picture of an IoT network complete attack surface.